

MA-6.1 · Preventive Maintenance Control Statement: Perform preventive maintenance on [organization-defined parameter] at [organization-defined parameter]. Supplemental Guidance: Perform preventive maintenance on [organization-defined parameter] at [organization-defined parameter]. Preventive maintenance includes proactive care and the servicing of system components to maintain organizational equipment and facilities in satisfactory operating condition. Such maintenance provides for the systematic inspection, tests, measurements, adjustments, parts replacement, detection, and correction of incipient failures either before they occur or before they develop into major defects. The primary goal of preventive maintenance is to avoid or mitigate the consequences of equipment failures. Preventive maintenance is designed to preserve and restore equipment reliability by replacing worn components before they fail. Methods of determining what preventive (or other) failure management policies to apply include original equipment manufacturer recommendations; statistical failure records; expert opinion; maintenance that has already been conducted on similar equipment; requirements of codes, laws, or regulations within a jurisdiction; or measured values and performance indications.

NIST SP 800-171 Rev 3 control 03.07.05 (03.07.05 Nonlocal Maintenance) is assessed by examining the following: Assessment Objectives: - nonlocal maintenance and diagnostic activities are approved. - nonlocal maintenance and diagnostic activities are monitored. - session connections are terminated when nonlocal maintenance is completed. - network connections are terminated when nonlocal maintenance is completed. - multi-factor authentication is implemented in the establishment of nonlocal maintenance and diagnostic sessions. - replay resistance is implemented in the establishment of nonlocal maintenance and diagnostic sessions.

Under the FedRAMP High baseline, MA-3.2 (MA-3.2 Inspect Media): FedRAMP High Baseline · MA-3.2 · Inspect Media Control Statement: Check media containing diagnostic and test programs for malicious code before the media are used in the system. Supplemental Guidance: Check media containing diagnostic and test programs for malicious code before the media are used in the system. If, upon inspection of media containing maintenance, diagnostic, and test programs, organizations determine that the media contains malicious code, the incident is handled consistent wi

NIST SP 800-53 Rev 5 control MA-3.2 (Inspect Media) is assessed by examining, interviewing, and testing: MA-3.2 · Inspect Media Control Statement: Check media containing diagnostic and test programs for malicious code before the media are used in the system. Supplemental Guidance: Check media containing diagnostic and test programs for malicious code before the media are used in the system. If, upon inspection of media containing maintenance, diagnostic, and test programs, organizations determine that the media contains malicious code, the incident is handled consistent with organizational incide

NIST SP 800-171 Rev 3 control 03.07.04 (03.07.04 Maintenance Tools) is assessed by examining the following: Assessment Objectives: - the use of system maintenance tools is approved. - the use of system maintenance tools is controlled. - the use of system maintenance tools is monitored. - media with diagnostic and test programs are checked for malicious code before the media are used in the system. - the removal of system maintenance equipment containing CUI is prevented by verifying that there is no CUI on the equipment, sanitizing or destroying the equipment, or retaining the equipment within the facility.

NIST SP 800-171 Rev 3 control 03.07.06 (03.07.06 Maintenance Personnel) is assessed by examining the following: Assessment Objectives: - a process for maintenance personnel authorization is established. - a list of authorized maintenance organizations or personnel is maintained. - organizational personnel with required access authorizations are designated to supervise the maintenance activities of personnel who do not possess the required access authorizations. - organizational personnel with required technical competence are designated to supervise the maintenance activities of personnel who do not possess the required access authorizations. - non-escorted personnel who perform maintenance on the syste

NIST SP 800-53 Rev 5 control MA-3.1 (Inspect Tools) summarizes the requirements for this control: MA-3.1 · Inspect Tools Control Statement: Inspect the maintenance tools used by maintenance personnel for improper or unauthorized modifications. Supplemental Guidance: Inspect the maintenance tools used by maintenance personnel for improper or unauthorized modifications. Maintenance tools can be directly brought into a facility by maintenance personnel or downloaded

from a vendor's website. If, upon inspection of the maintenance tools, organizations determine that the tools have been modified

NIST SP 800-53 Rev 5 control MA-4.3 (Comparable Security and Sanitization) summarizes the requirements for this control: MA-4.3 · Comparable Security and Sanitization Control Statement: (a) Require that nonlocal maintenance and diagnostic services be performed from a system that implements a security capability comparable to the capability implemented on the system being serviced; or (b) Remove the component to be serviced from the system prior to nonlocal maintenance or diagnostic services; sanitize the component (for organizational information); and after the service is performed, inspect and sanitize the compo

Under the FedRAMP Low baseline, MA-2 (MA-2 Controlled Maintenance): FedRAMP Low Baseline · MA-2 · Controlled Maintenance Control Statement: a. Schedule, document, and review records of maintenance, repair, and replacement on system components in accordance with manufacturer or vendor specifications and/or organizational requirements; b. Approve and monitor all maintenance activities, whether performed on site or remotely and whether the system or system components are serviced on site or removed to another location; c. Require that [organization-defined paramet

Under the FedRAMP Moderate baseline, MA-6 (MA-6 Timely Maintenance): FedRAMP Moderate Baseline · MA-6 · Timely Maintenance Control Statement: Obtain maintenance support and/or spare parts for [organization-defined parameter] within [organization-defined parameter] of failure. Supplemental Guidance: Obtain maintenance support and/or spare parts for [organization-defined parameter] within [organization-defined parameter] of failure. Organizations specify the system components that result in increased risk to organizational operations and assets, individuals, othe

NIST SP 800-53 Rev 5 control MA-2 (Controlled Maintenance) is assessed by examining, interviewing, and testing: MA-2 · Controlled Maintenance Control Statement: a. Schedule, document, and review records of maintenance, repair, and replacement on system components in accordance with manufacturer or vendor specifications and/or organizational requirements; b. Approve and monitor all maintenance activities, whether performed on site or remotely and whether the system or system components are serviced on site or removed to another location; c. Require that [organization-defined parameter] explicitly approve

NIST SP 800-171 Rev 3 control 03.07.05 (03.07.05 Nonlocal Maintenance) is assessed by examining the following: Assessment Objectives: - nonlocal maintenance and diagnostic activities are approved. - nonlocal maintenance and diagnostic activities are monitored. - session connections are terminated when nonlocal maintenance is completed. - network connections are terminated when nonlocal maintenance is completed. - multi-factor authentication is implemented in the establishment of nonlocal maintenance and diagnostic sessions. - replay resistance is implemented in the establishment of nonlocal maintenance and diagnostic sessions.

NIST SP 800-53 Rev 5 control MA-4.7 (Disconnect Verification) summarizes the requirements for this control: MA-4.7 · Disconnect Verification Control Statement: Verify session and network connection termination after the completion of nonlocal maintenance and diagnostic sessions. Supplemental Guidance: Verify session and network connection termination after the completion of nonlocal maintenance and diagnostic sessions. Verifying the termination of a connection once maintenance is completed ensures that connections established during nonlocal maintenance and diagnostic sessions have been terminated a

NIST SP 800-171 Rev 3 control 03.07.04 (03.07.04 Maintenance Tools) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Maintenance (MA) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

Control AM-1: riodically to ensure that risk and response assumptions and processes are current with respect to evolving ransomware threats. Testing of response and recovery plans should include any associated ICS. Processes need to be updated and maintained to match changing organizational needs and structures as well as new ransomware types and tactics. Testing trains the people who will need to execute the plan. || Maintenance (PR.MA): Maintenance and repairs of industrial control and

information system components are performed consistent with policies and procedures. | PR.MA-2: Remote maintenance of organizational assets is approved, logged, and performed in a manner that prevents unauthorized access ISO/IEC 27001:2013 A.11.2.4, A.15.1.1, A.15.2.1 NIST SP 800-53 Rev. 5 MA-4 | Remote maintenance provides an access channel into networks and technology. If not managed properly, criminals may use this access to alter configurations to permit introduction of malware. Remote maintenance of all system components by the organization or its providers must be validated to ensure that this process does not provide backdoor access to OT or IT networks.

NIST SP 800-53 Rev 5 control MA-3.6 (Software Updates and Patches) summarizes the requirements for this control: MA-3.6 · Software Updates and Patches Control Statement: Inspect maintenance tools to ensure the latest software updates and patches are installed. Supplemental Guidance: Inspect maintenance tools to ensure the latest software updates and patches are installed. Maintenance tools using outdated and/or unpatched software can provide a threat vector for adversaries and result in a significant vulnerability for organizations.

Under the FedRAMP Low baseline, MA-1 (MA-1 Policy and Procedures): FedRAMP Low Baseline · MA-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] maintenance policy that: 2. Procedures to facilitate the implementation of the maintenance policy and the associated maintenance controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination of the maintenance policy and procedures; and c. Review and upda

NIST SP 800-53 Rev 5 control MA-5.2 (Security Clearances for Classified Systems) summarizes the requirements for this control: MA-5.2 · Security Clearances for Classified Systems Control Statement: Verify that personnel performing maintenance and diagnostic activities on a system processing, storing, or transmitting classified information possess security clearances and formal access approvals for at least the highest classification level and for compartments of information on the system. Supplemental Guidance: Verify that personnel performing maintenance and diagnostic activities on a system processing, storing, or t

NIST SP 800-171 Rev 3 control 03.07.04 (03.07.04 Maintenance Tools) falls under the Maintenance family. Control Statement: SR-03.07.04.a Approve, control, and monitor the use of system maintenance tools. SR-03.07.04.b Check media with diagnostic and test programs for malicious code before it is used in the system. SR-03.07.04.c Prevent the removal of system maintenance equipment containing CUI by verifying that there is no CUI on the equipment, sanitizing or destroying the equipment, or retaining the equipment within the facility. Supplemental Guidance: Approving, controlling, monitoring, and reviewing maintenance tools address security-related issues associated with the tools that are used for diagnostic and repair actions on the system. Maintenance tools can include hardware and software diagnostic and test equipment as well as packet sniffers. The tools may be pre-installed, brought in with maintenance personnel on media, cloud-based, or downloaded from a website. Diagnostic and test programs are potential vehicles for

NIST SP 800-53 Rev 5 control MA-4.3 (Comparable Security and Sanitization) is assessed by examining, interviewing, and testing: MA-4.3 · Comparable Security and Sanitization Control Statement: (a) Require that nonlocal maintenance and diagnostic services be performed from a system that implements a security capability comparable to the capability implemented on the system being serviced; or (b) Remove the component to be serviced from the system prior to nonlocal maintenance or diagnostic services; sanitize the component (for organizational information); and after the service is performed, inspect and sanitize the compo

NIST SP 800-53 Rev 5 control MA-2.2 (Automated Maintenance Activities) is defined as follows: MA-2.2 · Automated Maintenance Activities Control Statement: (a) Schedule, conduct, and document maintenance, repair, and replacement actions for the system using [organization-defined parameter] ; and (b) Produce up-to date, accurate, and complete records of all maintenance, repair, and replacement actions requested, scheduled, in process, and completed. Supplemental Guidance: (a) Schedule, conduct, and document maintenance, repair, and replacement actions for the system using [organization-defined parameter] ; and (b) Produce up-to date, accurate, and complete records of all maintenance, r

Under the FedRAMP Moderate baseline, MA-1 (MA-1 Policy and Procedures): FedRAMP Moderate Baseline ·

MA-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] maintenance policy that: 2. Procedures to facilitate the implementation of the maintenance policy and the associated maintenance controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination of the maintenance policy and procedures; and c. Review and

NIST SP 800-53 Rev 5 control MA-4 (Nonlocal Maintenance) is assessed by examining, interviewing, and testing: MA-4 · Nonlocal Maintenance Control Statement: a. Approve and monitor nonlocal maintenance and diagnostic activities; b. Allow the use of nonlocal maintenance and diagnostic tools only as consistent with organizational policy and documented in the security plan for the system; c. Employ strong authentication in the establishment of nonlocal maintenance and diagnostic sessions; d. Maintain records for nonlocal maintenance and diagnostic activities; and e. Terminate session and network connection

NIST SP 800-53 Rev 5 control MA-1 (Policy and Procedures) summarizes the requirements for this control: MA-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] maintenance policy that: 2. Procedures to facilitate the implementation of the maintenance policy and the associated maintenance controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination of the maintenance policy and procedures; and c. Review and update the current maintainan

MA-6.2 · Predictive Maintenance Control Statement: Perform predictive maintenance on [organization-defined parameter] at [organization-defined parameter]. Supplemental Guidance: Perform predictive maintenance on [organization-defined parameter] at [organization-defined parameter]. Predictive maintenance evaluates the condition of equipment by performing periodic or continuous (online) equipment condition monitoring. The goal of predictive maintenance is to perform maintenance at a scheduled time when the maintenance activity is most cost-effective and before the equipment loses performance within a threshold. The predictive component of predictive maintenance stems from the objective of predicting the future trend of the equipment's condition. The predictive maintenance approach employs principles of statistical process control to determine at what point in the future maintenance activities will be appropriate. Most predictive maintenance inspections are performed while equipment is in service, thus minimizing disruption of normal system operations. Predictive maintenance can result in substantial cost savings and higher system reliability.

NIST SP 800-53 Rev 5 control MA-3.5 (Execution with Privilege) is defined as follows: MA-3.5 · Execution with Privilege Control Statement: Monitor the use of maintenance tools that execute with increased privilege. Supplemental Guidance: Monitor the use of maintenance tools that execute with increased privilege. Maintenance tools that execute with increased system privilege can result in unauthorized access to organizational information and assets that would otherwise be inaccessible.

NIST SP 800-53 Rev 5 control MA-5.2 (Security Clearances for Classified Systems) is assessed by examining, interviewing, and testing: MA-5.2 · Security Clearances for Classified Systems Control Statement: Verify that personnel performing maintenance and diagnostic activities on a system processing, storing, or transmitting classified information possess security clearances and formal access approvals for at least the highest classification level and for compartments of information on the system. Supplemental Guidance: Verify that personnel performing maintenance and diagnostic activities on a system processing, storing, or t

NIST SP 800-53 Rev 5 control MA-3.1 (Inspect Tools) is defined as follows: MA-3.1 · Inspect Tools Control Statement: Inspect the maintenance tools used by maintenance personnel for improper or unauthorized modifications. Supplemental Guidance: Inspect the maintenance tools used by maintenance personnel for improper or unauthorized modifications. Maintenance tools can be directly brought into a facility by maintenance personnel or downloaded from a vendor's website. If, upon inspection of the maintenance tools, organizations determine that the tools have been modified in an improper manner or the tools contain malicious code, the incident is handled consistent with

Under the FedRAMP High baseline, MA-6 (MA-6 Timely Maintenance): FedRAMP High Baseline · MA-6 · Timely Maintenance Control Statement: Obtain maintenance support and/or spare parts for [organization-defined parameter] within [organization-defined parameter] of failure. Supplemental

Guidance: Obtain maintenance support and/or spare parts for [organization-defined parameter] within [organization-defined parameter] of failure. Organizations specify the system components that result in increased risk to organizational operations and assets, individuals, other or

MA-6 · Timely Maintenance Control Statement: Obtain maintenance support and/or spare parts for [organization-defined parameter] within [organization-defined parameter] of failure. Supplemental Guidance: Obtain maintenance support and/or spare parts for [organization-defined parameter] within [organization-defined parameter] of failure. Organizations specify the system components that result in increased risk to organizational operations and assets, individuals, other organizations, or the Nation when the functionality provided by those components is not operational. Organizational actions to obtain maintenance support include having appropriate contracts in place.

NIST SP 800-53 Rev 5 control MA-6.2 (Predictive Maintenance) is assessed by examining, interviewing, and testing: MA-6.2 · Predictive Maintenance Control Statement: Perform predictive maintenance on [organization-defined parameter] at [organization-defined parameter]. Supplemental Guidance: Perform predictive maintenance on [organization-defined parameter] at [organization-defined parameter]. Predictive maintenance evaluates the condition of equipment by performing periodic or continuous (online) equipment condition monitoring. The goal of predictive maintenance is to perform maintenance at a scheduled ti

Under the FedRAMP Moderate baseline, MA-4 (MA-4 Nonlocal Maintenance): FedRAMP Moderate Baseline · MA-4 · Nonlocal Maintenance Control Statement: a. Approve and monitor nonlocal maintenance and diagnostic activities; b. Allow the use of nonlocal maintenance and diagnostic tools only as consistent with organizational policy and documented in the security plan for the system; c. Employ strong authentication in the establishment of nonlocal maintenance and diagnostic sessions; d. Maintain records for nonlocal maintenance and diagnostic activities; and e. Terminate se

Under the FedRAMP High baseline, MA-3 (MA-3 Maintenance Tools): FedRAMP High Baseline · MA-3 · Maintenance Tools Control Statement: a. Approve, control, and monitor the use of system maintenance tools; and b. Review previously approved system maintenance tools [organization-defined parameter]. Supplemental Guidance: a. Approve, control, and monitor the use of system maintenance tools; and b. Review previously approved system maintenance tools [organization-defined parameter]. Approving, controlling, monitoring, and reviewing maintenance tools address secur

NIST SP 800-171 Rev 3 control 03.07.06 (03.07.06 Maintenance Personnel) requires organizations to implement the following: Control Statement: SR-03.07.06.a Establish a process for maintenance personnel authorization. SR-03.07.06.b Maintain a list of authorized maintenance organizations or personnel. SR-03.07.06.c Verify that non-escorted personnel who perform maintenance on the system possess the required access authorizations. SR-03.07.06.d Designate organizational personnel with required access authorizations and technical competence to supervise the maintenance activities of personnel who do not possess the required access authorizations. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.07.06.

Under the FedRAMP Moderate baseline, MA-3 (MA-3 Maintenance Tools): FedRAMP Moderate Baseline · MA-3 · Maintenance Tools Control Statement: a. Approve, control, and monitor the use of system maintenance tools; and b. Review previously approved system maintenance tools [organization-defined parameter]. Supplemental Guidance: a. Approve, control, and monitor the use of system maintenance tools; and b. Review previously approved system maintenance tools [organization-defined parameter]. Approving, controlling, monitoring, and reviewing maintenance tools address s

Under the FedRAMP Low baseline, MA-4 (MA-4 Nonlocal Maintenance): FedRAMP Low Baseline · MA-4 · Nonlocal Maintenance Control Statement: a. Approve and monitor nonlocal maintenance and diagnostic activities; b. Allow the use of nonlocal maintenance and diagnostic tools only as consistent with organizational policy and documented in the security plan for the system; c. Employ strong authentication in the establishment of nonlocal maintenance and diagnostic sessions; d. Maintain records for nonlocal maintenance and diagnostic activities; and e. Terminate session

Under the FedRAMP High baseline, MA-1 (MA-1 Policy and Procedures): FedRAMP High Baseline · MA-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-

defined parameter]: 1. [organization-defined parameter] maintenance policy that: 2. Procedures to facilitate the implementation of the maintenance policy and the associated maintenance controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination of the maintenance policy and procedures; and c. Review and upd

NIST SP 800-53 Rev 5 control MA-5.1 (Individuals Without Appropriate Access) summarizes the requirements for this control: MA-5.1 · Individuals Without Appropriate Access Control Statement: (a) Implement procedures for the use of maintenance personnel that lack appropriate security clearances or are not U.S. citizens, that include the following requirements: (1) Maintenance personnel who do not have needed access authorizations, clearances, or formal access approvals are escorted and supervised during the performance of maintenance and diagnostic activities on the system by approved organizational personnel who a

NIST SP 800-53 Rev 5 control MA-3.4 (Restricted Tool Use) summarizes the requirements for this control: MA-3.4 · Restricted Tool Use Control Statement: Restrict the use of maintenance tools to authorized personnel only. Supplemental Guidance: Restrict the use of maintenance tools to authorized personnel only. Restricting the use of maintenance tools to only authorized personnel applies to systems that are used to carry out maintenance functions.

MA-3.5 · Execution with Privilege Control Statement: Monitor the use of maintenance tools that execute with increased privilege. Supplemental Guidance: Monitor the use of maintenance tools that execute with increased privilege. Maintenance tools that execute with increased system privilege can result in unauthorized access to organizational information and assets that would otherwise be inaccessible.

NIST SP 800-53 Rev 5 control MA-3 (Maintenance Tools) is assessed by examining, interviewing, and testing: MA-3 · Maintenance Tools Control Statement: a. Approve, control, and monitor the use of system maintenance tools; and b. Review previously approved system maintenance tools [organization-defined parameter]. Supplemental Guidance: a. Approve, control, and monitor the use of system maintenance tools; and b. Review previously approved system maintenance tools [organization-defined parameter]. Approving, controlling, monitoring, and reviewing maintenance tools address security-related issues assoc

Control OC-01: -----| | RS.MA-01 | The incident response plan is executed in coordination with relevant third parties once an incident is declared | High | next steps to be taken. R1: Detection technologies should automatically report incidents that they have confirmed. C1: Consider designating an incident lead for each incident. R2: If appropriate, contact the organization's incident response service provider to request assistance. R3: Initiate execution of other cybersecurity plans as needed (e.g., business continuity and disaster recovery | | RS.MA-02 | Incident reports are triaged and validated | High | R1: Perform a preliminary review of a new incident report to verify that a cybersecurity incident has occurred, then estimate the severity of the incident and the level of urgency needed to respond to it. R2: Have mechanisms in place for third parties to report possible incidents that involve the organization. Reports should be carefully monitored and taken seriously. For example, the organization might be contacted by a party claiming that its systems are being attacked by a system at the organization. External users may report other indicators, such as an unavailable service. Other incident response teams may also report incidents to the organization. Perform a more detailed review of | | RS.MA-03 | Incidents are categorized and prioritized | High | R1: incidents to help categorize them by incident type (e.g., data breach, ransomware, account takeover, denial of service).

NIST SP 800-53 Rev 5 control MA-4.6 (Cryptographic Protection) is assessed by examining, interviewing, and testing: MA-4.6 · Cryptographic Protection Control Statement: Implement the following cryptographic mechanisms to protect the integrity and confidentiality of nonlocal maintenance and diagnostic communications: [organization-defined parameter]. Supplemental Guidance: Implement the following cryptographic mechanisms to protect the integrity and confidentiality of nonlocal maintenance and diagnostic communications: [organization-defined parameter]. Failure to protect nonlocal maintenance and diagnostic c

Review previously approved system maintenance tools [Assignment: organization-defined frequency]. Discussion: Approving, controlling, monitoring, and reviewing maintenance tools address security-related issues associated with maintenance tools that are not within system authorization boundaries and are used specifically for diagnostic and repair actions on organizational systems. Organizations have flexibility in determining roles for the approval of maintenance tools and how that approval is documented. A periodic review of maintenance tools facilitates the withdrawal of approval for outdated, unsupported, irrelevant, or no-longer-used tools. Maintenance tools can include hardware, software, and firmware items and may be pre-installed, brought in with maintenance personnel on media, cloud-based, or downloaded from a website. Such tools can be vehicles for transporting malicious code, either intentionally or unintentionally, into a facility and subsequently into systems. Maintenance tools can include hardware and software diagnostic test equipment and packet sniffers. The hardware and software components that support maintenance and are a part of the system (including the software implementing utilities such as ping, ls, ipconfig, or the hardware and software implementing the monitoring port of an Ethernet switch) are not addressed by maintenance tools.

NIST SP 800-171 Rev 3 control 03.07.06 (03.07.06 Maintenance Personnel) is assessed by examining the following: Assessment Objectives: - a process for maintenance personnel authorization is established. - a list of authorized maintenance organizations or personnel is maintained. - organizational personnel with required access authorizations are designated to supervise the maintenance activities of personnel who do not possess the required access authorizations. - organizational personnel with required technical competence are designated to supervise the maintenance activities of personnel who do not possess the required access authorizations. - non-escorted personnel who perform maintenance on the system

NIST SP 800-53 Rev 5 control MA-5.5 (Non-system Maintenance) is assessed by examining, interviewing, and testing: MA-5.5 · Non-system Maintenance Control Statement: Ensure that non-escorted personnel performing maintenance activities not directly associated with the system but in the physical proximity of the system, have required access authorizations. Supplemental Guidance: Ensure that non-escorted personnel performing maintenance activities not directly associated with the system but in the physical proximity of the system, have required access authorizations. Personnel who perform maintenance activities

NIST SP 800-171 Rev 3 control 03.07.05 (03.07.05 Nonlocal Maintenance) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Maintenance (MA) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-53 Rev 5 control MA-1 (Policy and Procedures) is assessed by examining, interviewing, and testing: MA-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] maintenance policy that: 2. Procedures to facilitate the implementation of the maintenance policy and the associated maintenance controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination of the maintenance policy and procedures; and c. Review and update the current maintenance

NIST SP 800-53 Rev 5 control MA-3.3 (Prevent Unauthorized Removal) summarizes the requirements for this control: MA-3.3 · Prevent Unauthorized Removal Control Statement: Prevent the removal of maintenance equipment containing organizational information by: (a) Verifying that there is no organizational information contained on the equipment; (b) Sanitizing or destroying the equipment; (c) Retaining the equipment within the facility; or (d) Obtaining an exemption from [organization-defined parameter] explicitly authorizing removal of the equipment from the facility. Supplemental Guidance: Prevent the removal

FedRAMP High Baseline · MA-2.2 · Automated Maintenance Activities Control Statement: (a) Schedule, conduct, and document maintenance, repair, and replacement actions for the system using [organization-defined parameter]; and (b) Produce up-to date, accurate, and complete records of all

maintenance, repair, and replacement actions requested, scheduled, in process, and completed. Supplemental Guidance: (a) Schedule, conduct, and document maintenance, repair, and replacement actions for the system using [organization-defined parameter] ; and (b) Produce up-to date, accurate, and complete records of all maintenance, repair, and replacement actions requested, scheduled, in process, and completed. The use of automated mechanisms to manage and control system maintenance programs and activities helps to ensure the generation of timely, accurate, complete, and consistent maintenance records. Assessment Objectives: (a) Schedule, conduct, and document maintenance, repair, and replacement actions for the system using [organization-defined parameter] ; and (b) Produce up-to date, accurate, and complete records of all maintenance, repair, and replacement actions requested, scheduled, in process, and completed. FedRAMP Parameter Values: ma-2.2_prm_1: organization-defined automated mechanisms ma-02.02_odp.01: automated mechanisms used to schedule maintenance, repair, and replacement actions for the system are defined; ma-02.02_odp.02: automated mechanisms used to conduct maintenance, repair, and replacement actions for the system are defined; ma-02.02_odp.03: automated mechanisms used to document maintenance, repair, and replacement actions for the system are defined;

Under the FedRAMP High baseline, MA-4 (MA-4 Nonlocal Maintenance): FedRAMP High Baseline · MA-4 · Nonlocal Maintenance Control Statement: a. Approve and monitor nonlocal maintenance and diagnostic activities; b. Allow the use of nonlocal maintenance and diagnostic tools only as consistent with organizational policy and documented in the security plan for the system; c. Employ strong authentication in the establishment of nonlocal maintenance and diagnostic sessions; d. Maintain records for nonlocal maintenance and diagnostic activities; and e. Terminate sessio

NIST SP 800-53 Rev 5 control MA-6.1 (Preventive Maintenance) is defined as follows: MA-6.1 · Preventive Maintenance Control Statement: Perform preventive maintenance on [organization-defined parameter] at [organization-defined parameter]. Supplemental Guidance: Perform preventive maintenance on [organization-defined parameter] at [organization-defined parameter]. Preventive maintenance includes proactive care and the servicing of system components to maintain organizational equipment and facilities in satisfactory operating condition. Such maintenance provides for the systematic inspection, tests, measurements, adjustments, parts replacement, detection, and correction of in

NIST SP 800-171 Rev 3 control 03.07.05 (03.07.05 Nonlocal Maintenance) requires organizations to implement the following: Control Statement: SR-03.07.05.a Approve and monitor nonlocal maintenance and diagnostic activities. SR-03.07.05.b Implement multi-factor authentication and replay resistance in the establishment of nonlocal maintenance and diagnostic sessions. SR-03.07.05.c Terminate session and network connections when nonlocal maintenance is completed. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.07.05.

NIST SP 800-53 Rev 5 control MA-4.4 (Authentication and Separation of Maintenance Sessions): MA-4.4 · Authentication and Separation of Maintenance Sessions Control Statement: Protect nonlocal maintenance sessions by: (a) Employing [organization-defined parameter] ; and (b) Separating the maintenance sessions from other network sessions with the system by either: (1) Physically separated communications paths; or (2) Logically separated communications paths. Supplemental Guidance: Pro

NIST SP 800-53 Rev 5 control MA-6.2 (Predictive Maintenance) summarizes the requirements for this control: MA-6.2 · Predictive Maintenance Control Statement: Perform predictive maintenance on [organization-defined parameter] at [organization-defined parameter]. Supplemental Guidance: Perform predictive maintenance on [organization-defined parameter] at [organization-defined parameter]. Predictive maintenance evaluates the condition of equipment by performing periodic or continuous (online) equipment condition monitoring. The goal of predictive maintenance is to perform maintenance at a scheduled ti

NIST SP 800-171 Rev 3 control 03.07.04 (03.07.04 Maintenance Tools) is assessed by examining the following: Assessment Objectives: - the use of system maintenance tools is approved. - the use of system maintenance tools is controlled. - the use of system maintenance tools is monitored. - media with diagnostic and test programs are checked for malicious code before the media are used in the system. - the removal of system maintenance equipment containing CUI is prevented by verifying that

there is no CUI on the equipment, sanitizing or destroying the equipment, or retaining the equipment within the facility.

NIST SP 800-171 Rev 3 control 03.07.04 (03.07.04 Maintenance Tools) requires organizations to implement the following: Control Statement: SR-03.07.04.a Approve, control, and monitor the use of system maintenance tools. SR-03.07.04.b Check media with diagnostic and test programs for malicious code before it is used in the system. SR-03.07.04.c Prevent the removal of system maintenance equipment containing CUI by verifying that there is no CUI on the equipment, sanitizing or destroying the equipment, or retaining the equipment within the facility. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.07.04.

NIST SP 800-53 Rev 5 control MA-3.1 (Inspect Tools) is assessed by examining, interviewing, and testing: MA-3.1 · Inspect Tools Control Statement: Inspect the maintenance tools used by maintenance personnel for improper or unauthorized modifications. Supplemental Guidance: Inspect the maintenance tools used by maintenance personnel for improper or unauthorized modifications. Maintenance tools can be directly brought into a facility by maintenance personnel or downloaded from a vendor's website. If, upon inspection of the maintenance tools, organizations determine that the tools have been modified

NIST SP 800-53 Rev 5 control MA-6 (Timely Maintenance) summarizes the requirements for this control: MA-6 · Timely Maintenance Control Statement: Obtain maintenance support and/or spare parts for [organization-defined parameter] within [organization-defined parameter] of failure. Supplemental Guidance: Obtain maintenance support and/or spare parts for [organization-defined parameter] within [organization-defined parameter] of failure. Organizations specify the system components that result in increased risk to organizational operations and assets, individuals, other organizations, or the Nation

NIST SP 800-53 Rev 5 control MA-5.4 (Foreign Nationals) is assessed by examining, interviewing, and testing: MA-5.4 · Foreign Nationals Control Statement: Ensure that: (a) Foreign nationals with appropriate security clearances are used to conduct maintenance and diagnostic activities on classified systems only when the systems are jointly owned and operated by the United States and foreign allied governments, or owned and operated solely by foreign allied governments; and (b) Approvals, consents, and detailed operational conditions regarding the use of foreign nationals to conduct maintenance and diag

NIST SP 800-53 Rev 5 control MA-4.4 (Authentication and Separation of Maintenance Sessions) summarizes the requirements for this control: MA-4.4 · Authentication and Separation of Maintenance Sessions Control Statement: Protect nonlocal maintenance sessions by: (a) Employing [organization-defined parameter] ; and (b) Separating the maintenance sessions from other network sessions with the system by either: (1) Physically separated communications paths; or (2) Logically separated communications paths. Supplemental Guidance: Protect nonlocal maintenance sessions by: (a) Employing [organization-defined parameter] ; and (b) Sepa

MA-4.5 · Approvals and Notifications Control Statement: (a) Require the approval of each nonlocal maintenance session by [organization-defined parameter] ; and (b) Notify the following personnel or roles of the date and time of planned nonlocal maintenance: [organization-defined parameter]. Supplemental Guidance: (a) Require the approval of each nonlocal maintenance session by [organization-defined parameter] ; and (b) Notify the following personnel or roles of the date and time of planned nonlocal maintenance: [organization-defined parameter]. Notification may be performed by maintenance personnel. Approval of nonlocal maintenance is accomplished by personnel with sufficient information security and system knowledge to determine the appropriateness of the proposed maintenance.

NIST SP 800-53 Rev 5 control MA-4.7 (Disconnect Verification) is assessed by examining, interviewing, and testing: MA-4.7 · Disconnect Verification Control Statement: Verify session and network connection termination after the completion of nonlocal maintenance and diagnostic sessions. Supplemental Guidance: Verify session and network connection termination after the completion of nonlocal maintenance and diagnostic sessions. Verifying the termination of a connection once maintenance is completed ensures that connections established during nonlocal maintenance and

diagnostic sessions have been terminated a

NIST SP 800-53 Rev 5 control MA-4.1 (Logging and Review) summarizes the requirements for this control: MA-4.1 · Logging and Review Control Statement: (a) Log [organization-defined parameter] for nonlocal maintenance and diagnostic sessions; and (b) Review the audit records of the maintenance and diagnostic sessions to detect anomalous behavior. Supplemental Guidance: (a) Log [organization-defined parameter] for nonlocal maintenance and diagnostic sessions; and (b) Review the audit records of the maintenance and diagnostic sessions to detect anomalous behavior. Audit logging for nonlocal mainten

Under the FedRAMP Moderate baseline, MA-3.3 (MA-3.3 Prevent Unauthorized Removal): FedRAMP Moderate Baseline · MA-3.3 · Prevent Unauthorized Removal Control Statement: Prevent the removal of maintenance equipment containing organizational information by: (a) Verifying that there is no organizational information contained on the equipment; (b) Sanitizing or destroying the equipment; (c) Retaining the equipment within the facility; or (d) Obtaining an exemption from [organization-defined parameter] explicitly authorizing removal of the equipment from the facility. Supplemental

NIST SP 800-53 Rev 5 control MA-4.4 (Authentication and Separation of Maintenance Sessions) is assessed by examining, interviewing, and testing: MA-4.4 · Authentication and Separation of Maintenance Sessions Control Statement: Protect nonlocal maintenance sessions by: (a) Employing [organization-defined parameter] ; and (b) Separating the maintenance sessions from other network sessions with the system by either: (1) Physically separated communications paths; or (2) Logically separated communications paths. Supplemental Guidance: Protect nonlocal maintenance sessions by: (a) Employing [organization-defined parameter] ; and (b) Sepa

Implementing 03.07.04 (03.07.04 Maintenance Tools) differs between cloud and on-premises environments in several ways: ****On-premises****: The organization has direct control over all infrastructure components. Implementation of 03.07.04 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control. ****Cloud (IaaS/PaaS/SaaS)****: Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles infrastructure-level controls (physical security, hypervisor, network backbone) - The organization handles application-level controls, user access, and data protection - The split depends on the service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document in their SSP which components of 03.07.04 are implemented by the CSP (with reference to the CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly defined regardless of environment.

Under the FedRAMP High baseline, MA-3.1 (MA-3.1 Inspect Tools): FedRAMP High Baseline · MA-3.1 · Inspect Tools Control Statement: Inspect the maintenance tools used by maintenance personnel for improper or unauthorized modifications. Supplemental Guidance: Inspect the maintenance tools used by maintenance personnel for improper or unauthorized modifications. Maintenance tools can be directly brought into a facility by maintenance personnel or downloaded from a vendor's website. If, upon inspection of the maintenance tools, organizations determine that the

NIST SP 800-53 Rev 5 control MA-6.1 (Preventive Maintenance) is assessed by examining, interviewing, and testing: MA-6.1 · Preventive Maintenance Control Statement: Perform preventive maintenance on [organization-defined parameter] at [organization-defined parameter]. Supplemental Guidance: Perform preventive maintenance on [organization-defined parameter] at [organization-defined parameter]. Preventive maintenance includes proactive care and the servicing of system components to maintain organizational equipment and facilities in satisfactory operating condition. Such maintenance provides for the systema

NIST SP 800-53 Rev 5 control MA-7 (Field Maintenance) is assessed by examining, interviewing, and testing: MA-7 · Field Maintenance Control Statement: Restrict or prohibit field maintenance on [organization-defined parameter] to [organization-defined parameter]. Supplemental Guidance: Restrict or prohibit field maintenance on [organization-defined parameter] to [organization-defined parameter]. Field maintenance is the type of maintenance conducted on a system or system component after the system or component has been deployed to a specific site (i.e., operational environment). In certain instances

